MINI-PROJET · ARCHITECTURE DE SOLUTION

MedX

Plateforme de santé — Architecture technique

Téléconsultation · Dossier patient · Accès d'urgence · e-Prescriptions

Auteurs : Ayman EL KARROUSSI · Abdoulaye FOFANA · Hamid AIT MIMOUN

Octobre 2026

Mini-projet académique

PRIORITÉ HAUTE | PRIORITÉ MOYENNE | PRIORITÉ BASSE

Code couleur utilisé dans tous les schémas et tableaux du document

Sommaire

1. Introduction 4

Décisions clés en un coup d'œil . . . 4

2. Hypothèses 4

Objectifs . . . 5

3. Couverture des exigences 5

4. Architecture générale 6

4.1 Exemple : réserver une consultation . . . 6

4.2 Pourquoi AWS à Paris . . . 7

5. Conception des composants 7

5.1 Gestion des utilisateurs . . . 7

5.2 Dossiers patients (avec le module Accès d'urgence) . . . 8

5.3 Planification des téléconsultations . . . 8

5.4 Consultation . . . 8

5.5 Gestion des prescriptions . . . 8

5.6 Interface pharmacie . . . 9

5.7 Notifications . . . 9

5.8 Facturation et paiement . . . 9

6. Modèle de données et stockage 10

6.1 Entités principales . . . 10

6.2 Choix de stockage . . . 10

6.3 Intégrité des données et données de test . . . 10

7. Sécurité et conformité 11

7.1 Chiffrement . . . 11

7.2 Connexion et autorisations . . . 11

7.3 Masquage des données . . . 11

7.4 Accès d'urgence . . . 11

7.5 Réseau . . . 12

7.6 Conformité . . . 12

8. Montée en charge et performance 13

8.1 Charge attendue . . . 13

8.2 Comment le système grandit . . . 13

8.3 Sous pression : protéger d'abord l'essentiel . . . 13

8.4 Supervision et tests . . . 13

9. Compromis **14**

10. Conclusion **14**

Annexe A — Architecture générale 15

Annexe B — Services, communication et cycle de vie des prescriptions 16

Annexe C — Modèle de données et stockage 17

Annexe D — Accès d'urgence 18

Annexe E — Sécurité : réseau, contrôle d'accès et masquage 19

1. Introduction

MedX est une plateforme de santé qui réunit téléconsultations, dossiers patients et prescriptions partagées avec les pharmacies. Ce document présente sa conception technique : l'architecture générale, chaque composant, le modèle de données, la montée en charge et la protection des données de santé.

L'annexe 2 du sujet indique clairement ce qui compte le plus : **protéger les données** (en transit et au repos) et **donner aux professionnels de santé un accès immédiat en cas d'urgence**. Le reste vient ensuite. La conception suit donc un principe simple :

> **L'effort suit la priorité.** Les fonctions de priorité haute bénéficient de la meilleure protection, de la plus forte redondance et des objectifs de performance les plus stricts. Les fonctions de priorité basse restent simples et peuvent ralentir en premier si le système est sous pression.

Décisions clés en un coup d'œil

Décision	Pourquoi
Huit services, un par domaine du sujet, sur AWS à Paris	Responsabilités claires ; chaque partie évolue et monte en charge indépendamment ; l'hébergement à Paris est certifié pour les données de santé (HDS).
Accès d'urgence intégré aux dossiers patients, avec un *résumé d'urgence* préparé à l'avance	Les informations vitales (allergies, groupe sanguin, traitements) sont prêtes et s'affichent en moins d'une seconde.
Chiffrement partout, plus un chiffrement supplémentaire des champs les plus sensibles	Même une sauvegarde volée ou un administrateur de base ne voit que des données illisibles.
Les dossiers médicaux ne sont jamais écrasés	Chaque modification crée une nouvelle version : rien n'est perdu et tout est traçable.
Les services communiquent par un bus d'événements	Un service de priorité basse lent ou en panne (ex. facturation) ne peut pas bloquer les soins.

2. Hypothèses

Le sujet ne donne ni volumes ni pays ; la conception repose donc sur les hypothèses ci-dessous. Elles sont faciles à modifier et l'architecture ne dépend pas de leurs valeurs exactes.

Sujet	Hypothèse
Pays	France / UE : le RGPD s'applique et les données de santé doivent être hébergées chez un hébergeur certifié HDS.
Taille (à 3 ans)	2 millions de patients, 20 000 médecins, 5 000 pharmacies, 8 millions de consultations par an.
Heure de pointe	Le lundi matin : environ 15 % des consultations de la journée en une heure.
Fournisseur cloud	AWS (région Paris, Francfort en secours), dans la continuité de notre projet FlyAway.
Conservation	Dossiers médicaux conservés 20 ans (réglementation française).

Objectifs

Objectif	Cible
Accès d'urgence	Informations vitales affichées en moins d'1 seconde ; disponible 99,99 % du temps
Pages et actions courantes	Moins de 300 ms pour la plupart des requêtes
Vidéo	Rejoindre une consultation en moins de 5 secondes ; jusqu'à 5 000 simultanées
Aucune perte de données	Données médicales : rien de perdu si un datacenter tombe ; quelques secondes au plus si toute la région tombe
Reprise	Moins de 15 minutes pour les services médicaux ; quelques heures pour les services de priorité basse

3. Couverture des exigences

Chaque exigence de l'annexe 2 du sujet, la partie de la conception qui y répond, et où elle est expliquée.

	Exigence	Réponse de la conception	Section
H	**Confidentialité des données**	HTTPS/TLS partout, chiffrement AWS KMS au repos, chiffrement supplémentaire des champs sensibles, aucune donnée médicale dans les messages ou notifications	§7.1
H	**Dossiers patients**	Service Dossiers patients, dossiers versionnés (jamais écrasés), notes médicales signées	§5.2, §6
H	**Accès d'urgence**	Résumé d'urgence préparé à l'avance ; accès « bris de glace » : tracé d'abord, limité dans le temps, patient informé, contrôlé	§7.4, Annexe D
H	**Authentification et autorisations**	Keycloak avec MFA pour les professionnels, rôles + règle de relation de soin	§7.2
H	**Intégrité des données**	Versionnement, empreintes des fichiers, stockage verrouillé (Object Lock), sauvegardes quotidiennes copiées à Francfort	§6.3
M	**Planification**	Réserver / déplacer / annuler, liste d'attente et file urgente, médecins notifiés	§5.3
M	**Consultations**	Vidéo et audio via Amazon Chime SDK, chat, partage de fichiers versés au dossier	§5.4
M	**Prescriptions**	Créer, modifier, révoquer ; pharmacie et patient notifiés à chaque étape	§5.5, Annexe B
M	**Masquage et caviardage**	Chaque rôle ne voit que ce dont il a besoin (tableau de masquage)	§7.3, Annexe E
M	**Agendas externes**	Google Agenda et Outlook : créneaux occupés lus ; blocs neutres « Occupé » écrits en retour	§5.3
B	Interface pharmacie	Portail pharmacie : confirmer la réception, mettre à jour le statut, vérifier le stock	§5.6
B	Préférences utilisateur	Stockées par la Gestion des utilisateurs, utilisées par les Notifications	§5.1
B	Suivi des notifications	Statut d'envoi et de lecture enregistré pour chaque message	§5.7
B	Anonymisation	Les environnements de test utilisent de faux patients générés (Synthea)	§6.3
B	Facturation et remboursements	Paiements Stripe (aucune donnée de carte chez MedX), factures, remboursements	§5.8

H = haute, M = moyenne, B = basse priorité.

4. Architecture générale

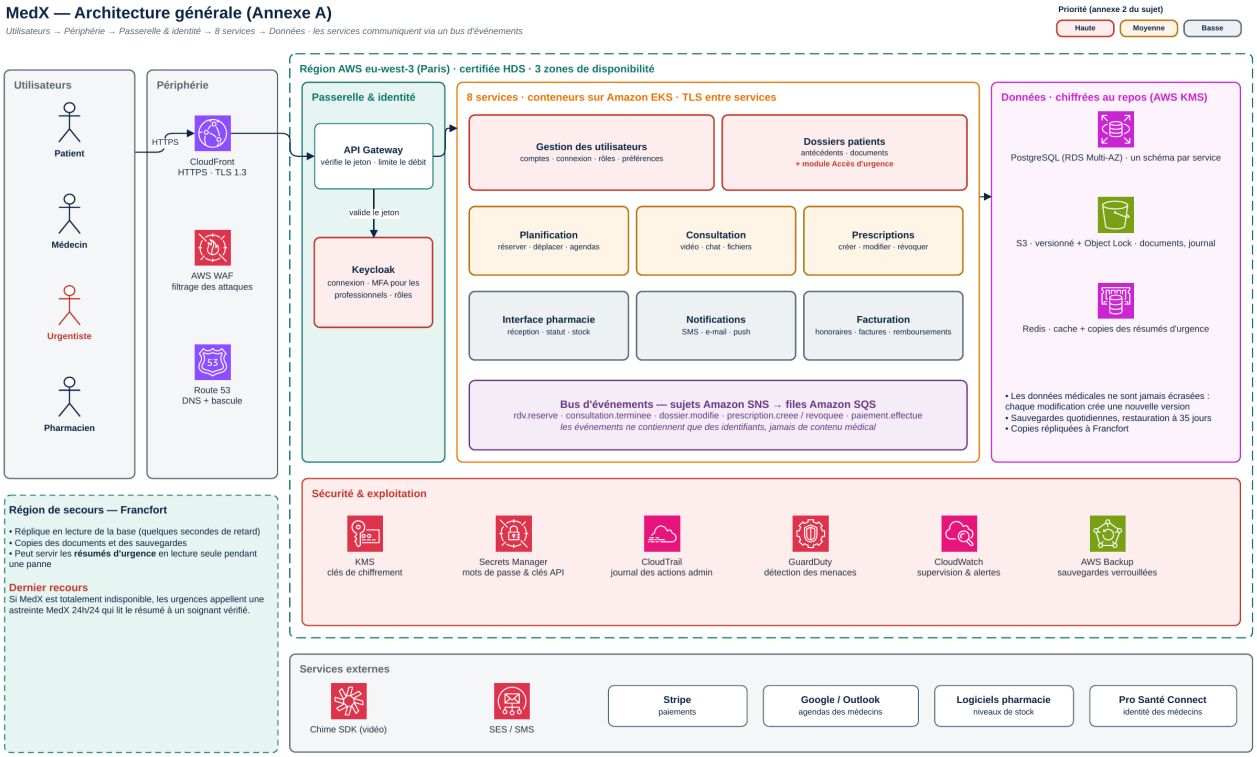


Figure 1 — Architecture générale (taille réelle en annexe A)

Le système est organisé en couches, à lire de gauche à droite sur la figure 1 :

- **Utilisateurs** — patients, médecins (dont urgentistes) et pharmaciens, via une application web ou mobile.
- **Périphérie** — CloudFront diffuse les applications et gère le HTTPS ; AWS WAF filtre les attaques courantes ; Route 53 peut basculer le trafic vers la région de secours.
- **Passerelle et identité** — l'API Gateway est le point d'entrée unique ; elle vérifie le jeton de connexion de chaque requête, émis par Keycloak.
- **Services** — huit services, un par domaine du sujet, exécutés en conteneurs sur Amazon EKS. Ils ne s'appellent directement que lorsqu'une réponse immédiate est nécessaire ; sinon ils échangent des messages via le **bus d'événements** (Amazon SNS + SQS).
- **Données** — PostgreSQL pour les données structurées, S3 pour les fichiers et le journal des accès, Redis pour les lectures rapides. Tout est chiffré.
- **Sécurité et exploitation** — gestion des clés, des secrets, journaux d'activité, détection des menaces, supervision et sauvegardes verrouillées.

4.1 Exemple : réserver une consultation

- Le patient choisit un créneau dans l'application ; la requête passe par CloudFront puis l'API Gateway, qui vérifie la connexion.
- Le service Planification enregistre le rendez-vous. La base de données refuse elle-même deux réservations du même créneau.
- Planification publie un événement *rdv.reserve* et répond immédiatement au patient.
- Notifications (confirmation et rappels), Consultation (prépare la salle vidéo) et Facturation réagissent à l'événement en arrière-plan.

4.2 Pourquoi AWS à Paris

La région AWS de Paris est certifiée pour l'hébergement de données de santé (HDS), exigé par la loi française, et Francfort offre une seconde région certifiée pour les sauvegardes. AWS fournit aussi des bases de données, du stockage et du chiffrement gérés, ce qui permet à l'équipe de se concentrer sur MedX. Nous avions utilisé AWS pour le projet FlyAway : ce choix s'appuie aussi sur une expérience existante.

5. Conception des composants

Les huit services reprennent directement l'annexe 1 du sujet. Chacun possède ses propres données : aucun service ne lit les tables d'un autre. La figure 2 montre comment ils communiquent. Il n'existe que quatre appels directs, tous dirigés vers un service plus critique : un problème dans un service de priorité basse ne peut donc jamais bloquer les soins.

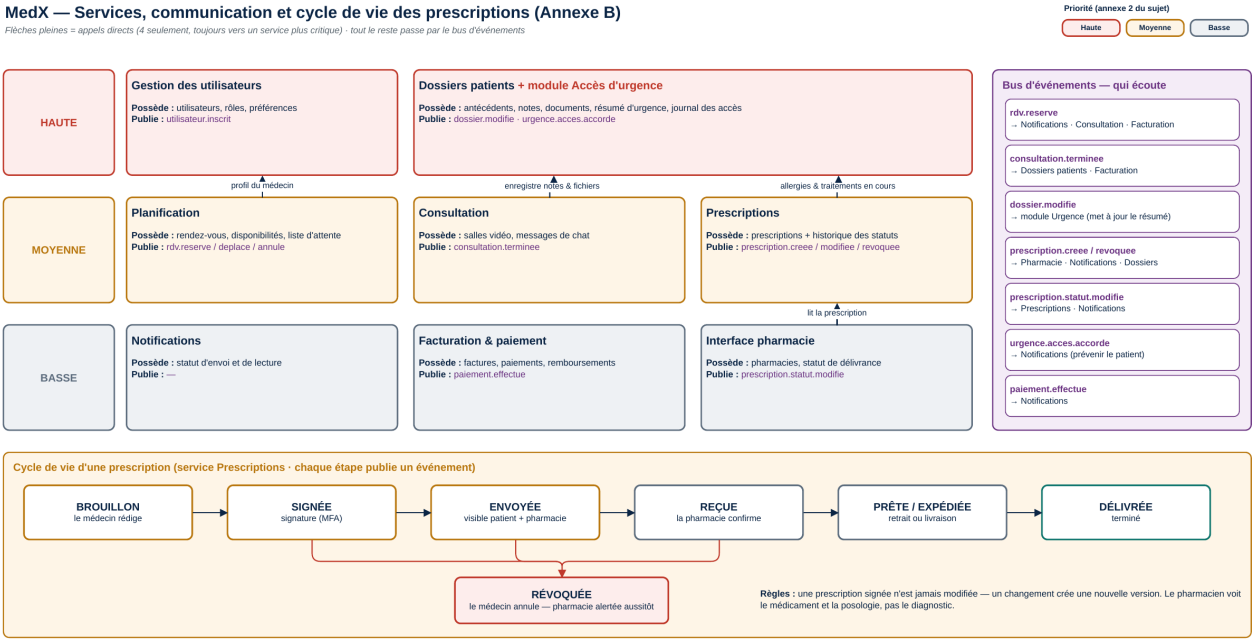


Figure 2 — Services, communication et cycle de vie des prescriptions (annexe B)

5.1 Gestion des utilisateurs

Gestion des utilisateurs PRIORITÉ HAUTE	
Rôle	Inscription et profils des patients, médecins et personnels de pharmacie ; rôles ; préférences (canaux de notification, langue, heures calmes).
Données	Profils dans PostgreSQL (coordonnées chiffrées). Les mots de passe ne sont gérés que par Keycloak.
Sécurité	Un compte médecin n'est activé qu'après vérification de son numéro RPPS, ou via une connexion Pro Santé Connect. MFA obligatoire pour les professionnels.

5.2 Dossiers patients (avec le module Accès d'urgence)

Dossiers patients PRIORITÉ HAUTE	
Rôle	Stocke antécédents, notes de consultation, allergies, résultats d'examens et documents. Les médecins ajoutent ou corrigent des entrées après une consultation ; les patients consultent leur propre dossier.
Données	Entrées du dossier dans PostgreSQL, selon le standard HL7 FHIR. Documents dans S3 avec une empreinte. Chaque modification crée une nouvelle version (auteur, date, motif) — rien n'est écrasé.
Module urgence	Tient à jour un **résumé d'urgence** par patient (groupe sanguin, allergies, traitements en cours, pathologies, contacts d'urgence), rafraîchi à chaque modification du dossier et copié dans Redis pour une lecture instantanée. Gère les demandes « bris de glace » (§7.4).
Sécurité	Un médecin ne peut ouvrir un dossier que s'il existe une relation de soin (§7.2). Chaque lecture est inscrite au journal des accès.

5.3 Planification des téléconsultations

Planification PRIORITÉ MOYENNE	
Rôle	Les patients réservent, déplacent ou annulent ; les médecins sont notifiés ; liste d'attente et file urgente (un créneau libéré va d'abord aux cas urgents).
Agendas	Connexion aux agendas Google ou Outlook des médecins : les créneaux occupés sont lus ; MedX écrit en retour un bloc neutre « Occupé », jamais le nom du patient.
Données	Rendez-vous dans PostgreSQL. Une règle de la base rend la double réservation impossible, même si deux patients cliquent au même instant.

5.4 Consultation

Consultation PRIORITÉ MOYENNE	
Rôle	Crée la salle virtuelle ; vidéo et audio ; chat ; partage de fichiers pendant la consultation.
Fonctionnement	La vidéo utilise Amazon Chime SDK, un service géré : MedX n'a pas de serveurs vidéo à exploiter. Les appels sont chiffrés et non enregistrés. Les fichiers partagés sont analysés (antivirus) puis versés au dossier patient. Si la connexion est faible, la vidéo passe en audio seul.
Données	Messages de chat dans PostgreSQL ; fichiers dans S3 via le service Dossiers patients.

5.5 Gestion des prescriptions

Prescriptions PRIORITÉ MOYENNE	
Rôle	Les médecins créent, modifient ou révoquent des prescriptions ; les patients voient leurs prescriptions actives ; les pharmacies sont notifiées ; la délivrance est suivie.
Cycle de vie	Brouillon → Signée → Envoyée → Reçue → Prête / Expédiée → Délivrée, ou Révoquée (figure 2). Une prescription signée n'est jamais modifiée : un changement crée une nouvelle version.
Sécurité	Avant de signer, le médecin voit les allergies et traitements en cours du patient, issus des Dossiers patients.

5.6 Interface pharmacie

Interface pharmacie PRIORITÉ BASSE	
Rôle	Les pharmacies confirment la réception et mettent à jour le statut (prête au retrait, expédiée) ; patients et pharmacies peuvent échanger des messages ; le stock est vérifié dans le logiciel de la pharmacie.
Sécurité	Le pharmacien voit le médicament, la posologie et le nom du patient — pas le diagnostic.

5.7 Notifications

Notifications PRIORITÉ BASSE	
Rôle	Envoie SMS, e-mails et messages dans l'application ; respecte les préférences de chacun ; enregistre si chaque message a été reçu et lu.
Confidentialité	Les messages ne contiennent jamais d'information médicale (« Vous avez un nouveau message sur MedX ») ; le détail n'est visible qu'après connexion.

5.8 Facturation et paiement

Facturation et paiement PRIORITÉ BASSE	
Rôle	Encaisse les honoraires et les médicaments, émet les factures, traite les remboursements (automatiquement si un médecin ne se présente pas).
Sécurité	Les paiements passent par Stripe : les numéros de carte n'atteignent jamais les serveurs MedX, ce qui exclut MedX de l'essentiel de la réglementation sur les cartes bancaires.

6. Modèle de données et stockage

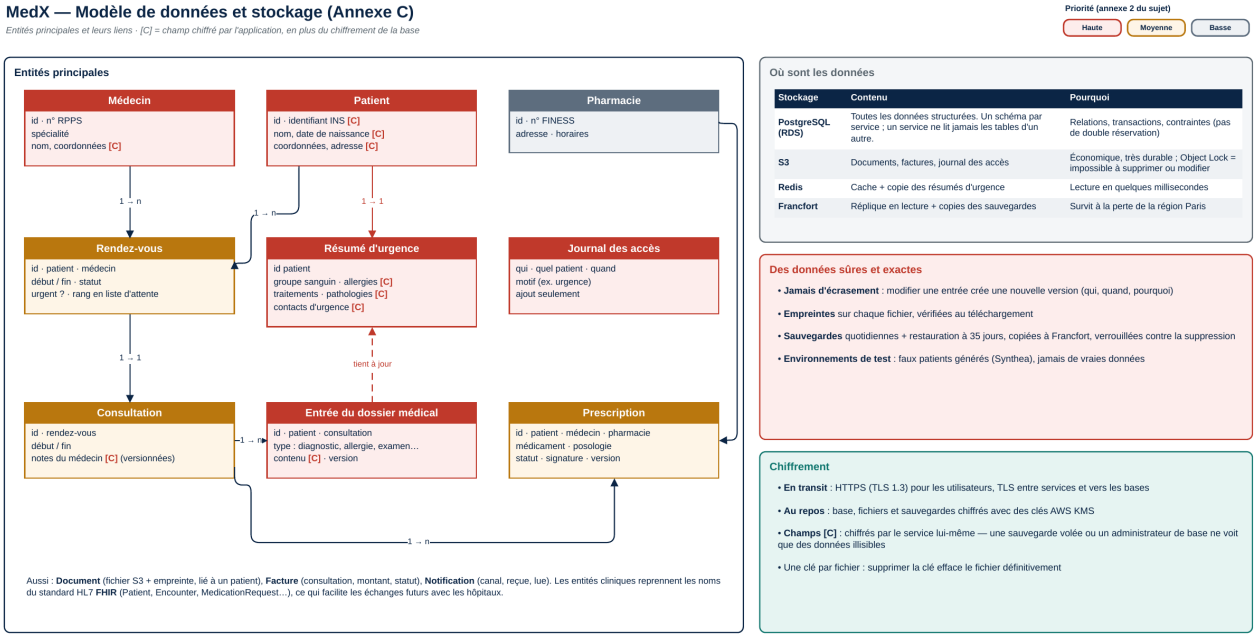


Figure 3 — Entités principales et stockage (annexe C)

6.1 Entités principales

Un **patient** a des **rendez-vous** avec des **médecins** ; chaque rendez-vous donne lieu à une **consultation**, qui produit des **entrées du dossier médical** et éventuellement des **prescriptions** envoyées à une **pharmacie**. Chaque patient a un **résumé d'urgence**, tenu à jour à partir de son dossier, et chaque accès à ses données est inscrit au **journal des accès**. Les entités cliniques reprennent les noms du standard HL7 FHIR, ce qui facilitera les échanges avec les hôpitaux.

6.2 Choix de stockage

Stockage	Contenu	Pourquoi ce choix
PostgreSQL (Amazon RDS, Multi-AZ)	Toutes les données structurées, un schéma par service	Transactions fiables et règles (ex. pas de double réservation) ; copie automatique dans 2 datacenters
Amazon S3	Documents, factures, journal des accès	Très durable et économique ; Object Lock empêche toute suppression ou modification
Redis (ElastiCache)	Cache et copies des résumés d'urgence	Réponse en quelques millisecondes — essentiel pour l'accès d'urgence
Région de Francfort	Réplique en lecture et copies des sauvegardes	Les données survivent même à la perte de toute la région Paris

Une seule base PostgreSQL avec un schéma par service garde l'ensemble simple tout en séparant les données de chaque service. Si un service a plus tard besoin de davantage de capacité, son schéma peut être déplacé dans sa propre base.

6.3 Intégrité des données et données de test

- **Versionnement** : les entrées médicales et les prescriptions ne sont jamais écrasées ; une correction est une nouvelle version.
- **Empreintes** : l'empreinte de chaque fichier est enregistrée au dépôt et vérifiée au téléchargement, pour détecter toute corruption.
- **Sauvegardes** : quotidiennes et automatiques, restauration à un instant donné sur 35 jours, copiées à Francfort et verrouillées contre la suppression. Une restauration est testée chaque mois.

- **Données de test** : les environnements de développement et de démonstration utilisent de faux patients réalistes générés par Synthea — les vraies données ne quittent jamais la production.

7. Sécurité et conformité

7.1 Chiffrement

Où	Comment
Entre les utilisateurs et MedX	HTTPS avec TLS 1.3
Entre services et bases de données	TLS sur chaque connexion interne
Données stockées (base, fichiers, sauvegardes)	Chiffrées avec des clés gérées par AWS KMS
Champs les plus sensibles (INS, coordonnées, notes, diagnostics)	Chiffrés une seconde fois par le service lui-même : une sauvegarde volée ou un administrateur de base ne voit que des données illisibles

7.2 Connexion et autorisations

Keycloak gère les connexions. Médecins, pharmaciens et administrateurs doivent utiliser l'authentification multifacteur ; les patients doivent l'activer pour consulter leur dossier. Les autorisations combinent deux contrôles : le **rôle** (quel type de données) et la **relation** (les données de qui). Un médecin ne peut ouvrir le dossier d'un patient que s'il a, ou a eu récemment, un rendez-vous avec lui, si le patient l'a autorisé, ou via l'accès d'urgence. Tout le reste est refusé, et chaque accès est tracé.

7.3 Masquage des données

Chaque rôle ne voit que ce dont il a besoin (tableau en annexe E). Par exemple, un pharmacien voit le nom et l'année de naissance du patient mais aucun diagnostic ; un agent du support ne voit que les quatre derniers chiffres de l'INS. Le masquage est appliqué dans le service avant l'envoi des données : aucune application ne peut le contourner. Un médecin peut aussi différer l'affichage d'une note sensible au patient jusqu'à l'annonce en personne d'un diagnostic difficile.

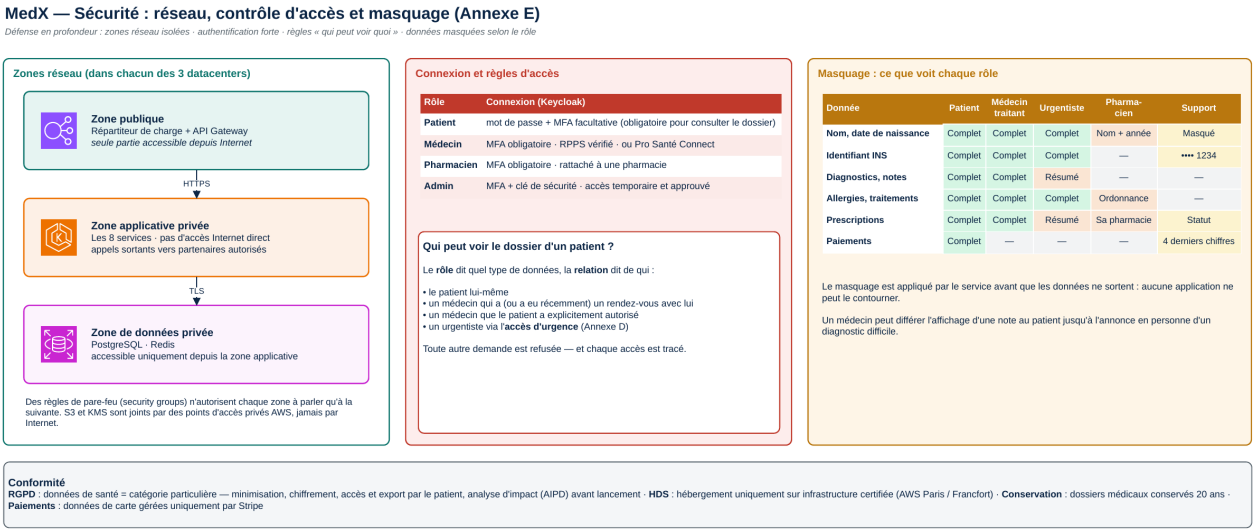


Figure 4 — Zones réseau, règles de connexion et masquage (annexe E)

7.4 Accès d'urgence

C'est la fonction où se rejoignent les deux priorités hautes : les données doivent être verrouillées, et pourtant disponibles immédiatement en cas d'urgence. Le déroulement (annexe D) est le suivant :

- L'urgentiste retrouve le patient et demande l'accès d'urgence en indiquant un motif. Il doit confirmer son identité par MFA.

- Le système vérifie qu'il s'agit d'un médecin avec un numéro RPPS actif.
- **Avant tout affichage**, une entrée est écrite dans le journal des accès (qui, quel patient, pourquoi, quand). Pas d'entrée au journal, pas de données.
- Le résumé d'urgence est lu dans Redis et affiché en moins d'une seconde, avec la mention « valable 60 minutes · accès tracé ».
- Le patient est informé de qui a consulté ses données, et un responsable conformité contrôle chaque accès d'urgence sous 72 heures.

En cas de panne : si Redis est indisponible, le résumé est lu dans la base ; si la région Paris est indisponible, la réplique de Francfort sert les résumés et le journal est écrit dans la copie S3 de Francfort ; si MedX est totalement indisponible, une astreinte 24h/24 peut lire le résumé à un soignant dont l'identité est vérifiée.

7.5 Réseau

Seuls le répartiteur de charge et l'API Gateway sont accessibles depuis Internet. Les services tournent dans une zone privée, et les bases dans une seconde zone privée que seuls les services peuvent joindre. Des règles de pare-feu n'autorisent chaque zone qu'à communiquer avec la suivante.

7.6 Conformité

- **RGPD** : les données de santé sont une catégorie particulière. MedX ne collecte que le nécessaire, chiffre les données, permet au patient de les consulter et de les exporter, et réalise une analyse d'impact (AIPD) avant le lancement. Les partenaires qui traitent des données personnelles (SMS, e-mail, Stripe) signent un contrat de sous-traitance.
- **HDS** : les données de santé sont hébergées uniquement sur une infrastructure certifiée HDS (AWS Paris et Francfort).
- **Traçabilité** : le journal des accès est verrouillé contre toute modification et conservé pour les contrôles et les autorités.

8. Montée en charge et performance

8.1 Charge attendue

Étape	Estimation
Consultations par jour ouvré	8 M / 250 jours ≈ 32 000
Heure de pointe (15 % de la journée)	≈ 4 800 consultations commencent
Appels vidéo simultanés	4 800 × 20 min / 60 min ≈ 1 600 → dimensionné pour 5 000 (marge pour les épidémies)
Requêtes vers l'API	≈ 60 requêtes par parcours de consultation, × 3 pour la navigation → ≈ 6 M par jour, ≈ 250 par seconde en pointe → dimensionné pour 1 000 par seconde

8.2 Comment le système grandit

- **La vidéo est gérée par Chime SDK** : en pointe, environ 15 Gbit/s de vidéo ne passent jamais par les serveurs de MedX. C'est la décision de montée en charge la plus importante.
- **Les services s'adaptent automatiquement** : Kubernetes ajoute des copies d'un service chargé et des serveurs si nécessaire.
- **Base de données** : des répliques en lecture soulagent la base principale ; Redis répond aux lectures les plus fréquentes.
- **Les fichiers** transitent directement entre l'application et S3, sans passer par les services.
- **Pics prévisibles** (lundi matin, épidémie de grippe) : la capacité est augmentée à l'avance.

8.3 Sous pression : protéger d'abord l'essentiel

Le bus d'événements permet à chaque service de travailler à son rythme. En cas de surcharge, le travail de priorité basse attend dans les files (notifications non urgentes, facturation, mises à jour de stock) et sera traité plus tard, tandis que les dossiers patients et l'accès d'urgence conservent leur capacité réservée. Le même ordre de priorité s'applique aux objectifs de reprise :

Priorité	Services	Perte de données si la région tombe	Remis en service sous
Haute	Dossiers patients, accès d'urgence, Gestion des utilisateurs	quelques secondes	15 min (résumés d'urgence : immédiatement, en lecture seule)
Moyenne	Planification, Consultation, Prescriptions	quelques secondes	1 heure
Basse	Pharmacie, Notifications, Facturation	jusqu'à 15 minutes	4 heures

8.4 Supervision et tests

Des tableaux de bord et des alertes suivent les temps de réponse et les erreurs de chaque service. Avant le lancement, des tests de charge simulent l'heure de pointe ; nous vérifions aussi les limites AWS (par exemple le nombre de réunions vidéo Chime simultanées) et demandons leur augmentation à l'avance.

9. Compromis

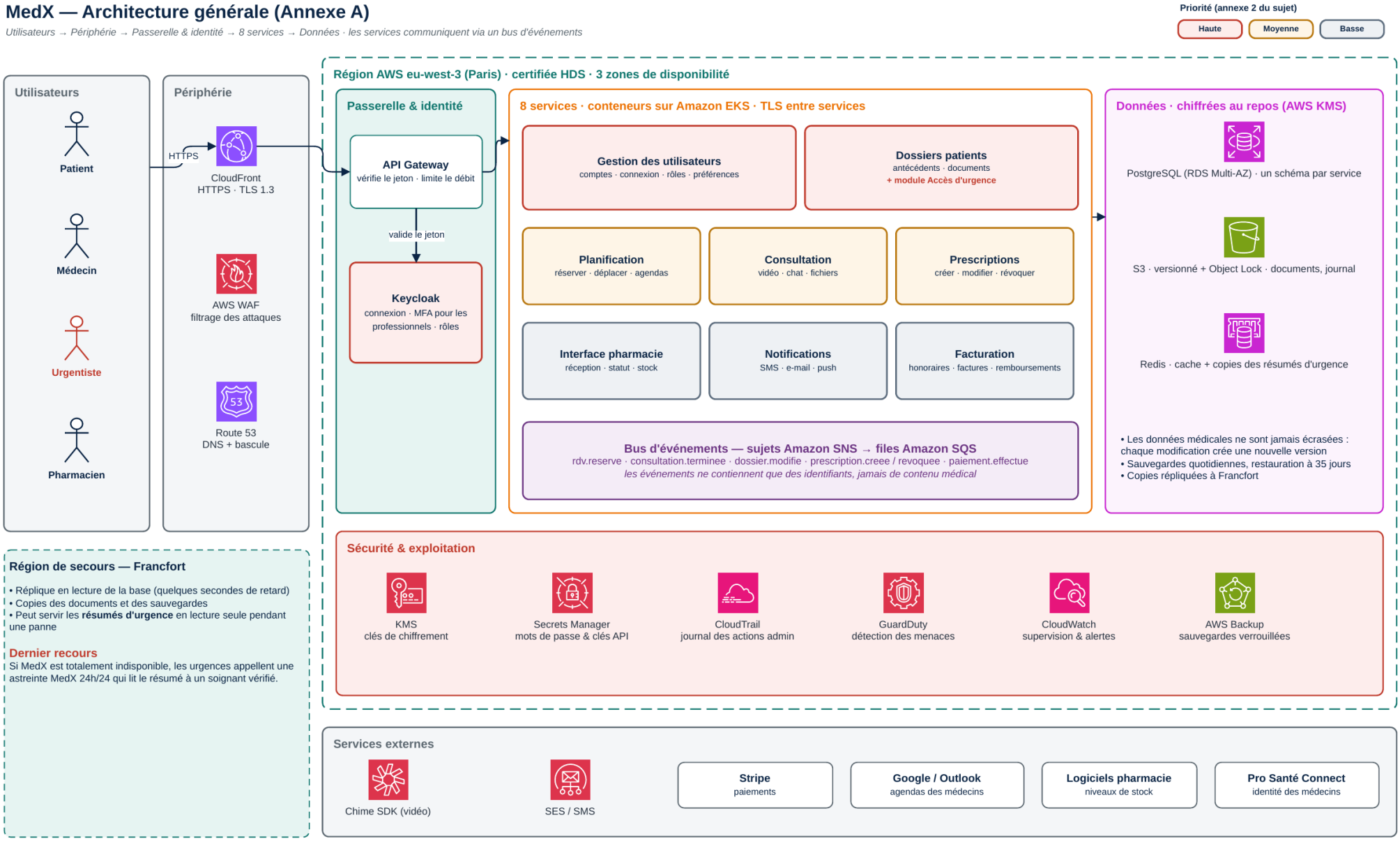
Choix	Alternative	Pourquoi ce choix	Ce qu'il nous coûte
8 services	Une seule application	Responsabilités claires, montée en charge séparée, pannes contenues	Plus d'éléments à déployer et superviser
Résumé d'urgence préparé	Lire le dossier complet en direct	Rapide, et fonctionne même si une partie du système est en panne	Peut avoir quelques secondes de retard sur le dossier
Bus d'événements (SNS + SQS)	Appels directs partout	Les services de priorité basse ne peuvent pas bloquer les soins	Certaines actions ont lieu un instant plus tard
Vidéo gérée (Chime SDK)	Nos propres serveurs vidéo	Aucun serveur vidéo à exploiter ni à dimensionner	Paiement à la minute ; dépendance à AWS
Une base, un schéma par service	Une base par service	Simple et moins coûteux	À séparer si un service grossit beaucoup
Chiffrement supplémentaire des champs	Chiffrement de la base seul	Protège même contre une sauvegarde volée ou un initié	Recherche libre impossible sur ces champs

10. Conclusion

La conception place au centre les deux premières priorités de MedX. Les données de santé sont chiffrées à chaque étape, jamais écrasées et visibles uniquement par les personnes qui ont une raison de les voir. L'accès d'urgence est rapide parce que les informations vitales sont préparées à l'avance, et sûr parce que chaque utilisation est d'abord tracée, limitée dans le temps, signalée au patient et contrôlée.

Les autres fonctions (planification, vidéo, prescriptions, pharmacies, notifications et paiements) reposent sur ce socle et restent proportionnées à leur priorité : fiables là où les soins en dépendent, plus simples et capables d'attendre ailleurs.

Annexe A — Architecture générale



Annexe B — Services, communication et cycle de vie des prescriptions

MedX — Services, communication et cycle de vie des prescriptions (Annexe B)

Flèches pleines = appels directs (4 seulement, toujours vers un service plus critique) · tout le reste passe par le bus d'événements

Priorité (annexe 2 du sujet) — Haute · Moyenne · Basse

HAUTE

Gestion des utilisateurs
Possède : utilisateurs, rôles, préférences
Publie : utilisateur.inscrit

Dossiers patients + module Accès d'urgence
Possède : antécédents, notes, documents, résumé d'urgence, journal des accès
Publie : dossier.modifie · urgence.acces.accorde

profil du médecin

enregistre notes & fichiers

allergies & traitements en cours

MOYENNE

Planification
Possède : rendez-vous, disponibilités, liste d'attente
Publie : rdv.reserve / deplace / annule

Consultation
Possède : salles vidéo, messages de chat
Publie : consultation.terminee

Prescriptions
Possède : prescriptions + historique des statuts
Publie : prescription.creee / modifiee / revoquee

lit la prescription

BASSE

Notifications
Possède : statut d'envoi et de lecture
Publie : —

Facturation & paiement
Possède : factures, paiements, remboursements
Publie : paiement.effectue

Interface pharmacie
Possède : pharmacies, statut de délivrance
Publie : prescription.statut.modifie

Bus d'événements — qui écoute

- **rdv.reserve** → Notifications · Consultation · Facturation
- **consultation.terminee** → Dossiers patients · Facturation
- **dossier.modifie** → module Urgence (met à jour le résumé)
- **prescription.creee / revoquee** → Pharmacie · Notifications · Dossiers
- **prescription.statut.modifie** → Prescriptions · Notifications
- **urgence.acces.accorde** → Notifications (prévenir le patient)
- **paiement.effectue** → Notifications

Cycle de vie d'une prescription (service Prescriptions · chaque étape publie un événement)

BROUILLON — le médecin rédige → **SIGNÉE** — signature (MFA) → **ENVOYÉE** — visible patient + pharmacie → **REÇUE** — la pharmacie confirme → **PRÊTE / EXPÉDIÉE** — retrait ou livraison → **DÉLIVRÉE** — terminé

RÉVOQUÉE — le médecin annule — pharmacie alertée aussitôt

Règles : une prescription signée n'est jamais modifiée — un changement crée une nouvelle version. Le pharmacien voit le médicament et la posologie, pas le diagnostic.

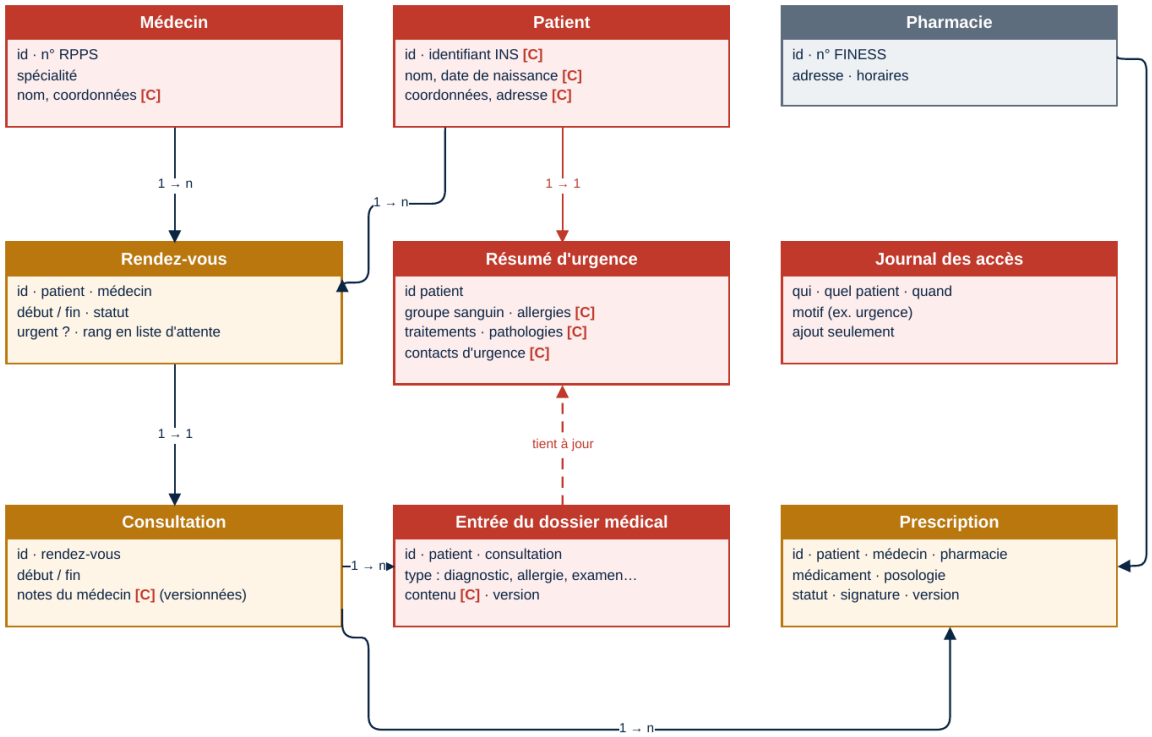
Annexe C — Modèle de données et stockage

MedX — Modèle de données et stockage (Annexe C)

Entités principales et leurs liens · [C] = champ chiffré par l'application, en plus du chiffrement de la base

Priorité (annexe 2 du sujet) : Haute · Moyenne · Basse

Entités principales



Aussi : **Document** (fichier S3 + empreinte, lié à un patient), **Facture** (consultation, montant, statut), **Notification** (canal, reçue, lue). Les entités cliniques reprennent les noms du standard HL7 **FHIR** (Patient, Encounter, MedicationRequest…), ce qui facilite les échanges futurs avec les hôpitaux.

Où sont les données

Stockage	Contenu	Pourquoi
PostgreSQL (RDS)	Toutes les données structurées. Un schéma par service ; un service ne lit jamais les tables d'un autre.	Relations, transactions, contraintes (pas de double réservation)
S3	Documents, factures, journal des accès	Économique, très durable ; Object Lock = impossible à supprimer ou modifier
Redis	Cache + copie des résumés d'urgence	Lecture en quelques millisecondes
Francfort	Réplique en lecture + copies des sauvegardes	Survit à la perte de la région Paris

Des données sûres et exactes

- **Jamais d'écrasement** : modifier une entrée crée une nouvelle version (qui, quand, pourquoi)
- **Empreintes** sur chaque fichier, vérifiées au téléchargement
- **Sauvegardes** quotidiennes + restauration à 35 jours, copiées à Francfort, verrouillées contre la suppression
- **Environnements de test** : faux patients générés (Synthea), jamais de vraies données

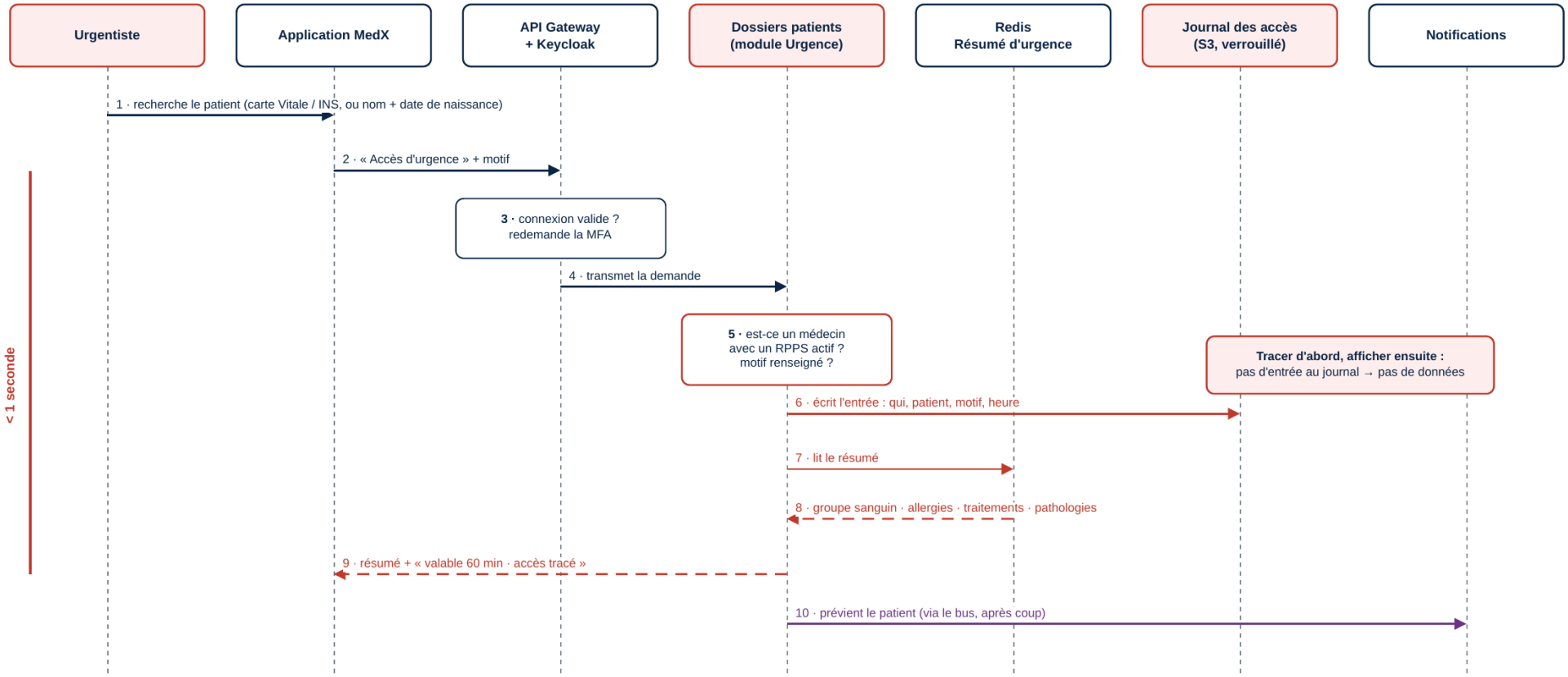
Chiffrement

- **En transit** : HTTPS (TLS 1.3) pour les utilisateurs, TLS entre services et vers les bases
- **Au repos** : base, fichiers et sauvegardes chiffrés avec des clés AWS KMS
- **Champs [C]** : chiffrés par le service lui-même — une sauvegarde volée ou un administrateur de base ne voit que des données illisibles
- Une clé par fichier : supprimer la clé efface le fichier définitivement

Annexe D — Accès d'urgence

MedX — Accès d'urgence (« bris de glace ») (Annexe D)

Un urgentiste obtient les informations vitales d'un patient en moins d'une seconde — chaque accès est tracé, limité dans le temps et contrôlé



Limité
Résumé uniquement (pas le dossier complet), lecture seule, expire au bout de 60 minutes.

Traçable
Chaque accès est inscrit dans un journal que personne ne peut modifier ni supprimer.

Transparent
Le patient est informé de qui a consulté ses données, et quand.

Contrôlé
Un responsable conformité vérifie chaque accès d'urgence sous 72 heures.

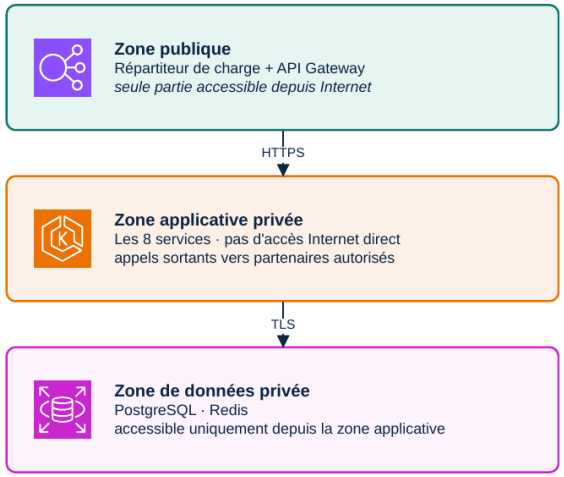
En cas de panne : Redis indisponible → le résumé est lu dans la base · région Paris indisponible → la réplique de Francfort sert les résumés et le journal est écrit dans la copie S3 de Francfort · MedX totalement indisponible → une astreinte 24h/24 lit le résumé à un soignant vérifié.

Annexe E — Sécurité : réseau, contrôle d'accès et masquage

MedX — Sécurité : réseau, contrôle d'accès et masquage (Annexe E)

Défense en profondeur : zones réseau isolées · authentification forte · règles « qui peut voir quoi » · données masquées selon le rôle

Zones réseau (dans chacun des 3 datacenters)



Des règles de pare-feu (security groups) n'autorisent chaque zone à parler qu'à la suivante. S3 et KMS sont joints par des points d'accès privés AWS, jamais par Internet.

Connexion et règles d'accès

Rôle	Connexion (Keycloak)
Patient	mot de passe + MFA facultative (obligatoire pour consulter le dossier)
Médecin	MFA obligatoire · RPPS vérifié · ou Pro Santé Connect
Pharmacien	MFA obligatoire · rattaché à une pharmacie
Admin	MFA + clé de sécurité · accès temporaire et approuvé

Qui peut voir le dossier d'un patient ?

Le **rôle** dit quel type de données, la **relation** dit de qui :

- le patient lui-même
- un médecin qui a (ou a eu récemment) un rendez-vous avec lui
- un médecin que le patient a explicitement autorisé
- un urgentiste via l'**accès d'urgence** (Annexe D)

Toute autre demande est refusée — et chaque accès est tracé.

Masquage : ce que voit chaque rôle

Donnée	Patient	Médecin traitant	Urgentiste	Pharma-cien	Support
Nom, date de naissance	Complet	Complet	Complet	Nom + année	Masqué
Identifiant INS	Complet	Complet	Complet	—	•••• 1234
Diagnostics, notes	Complet	Complet	Résumé	—	—
Allergies, traitements	Complet	Complet	Complet	Ordonnance	—
Prescriptions	Complet	Complet	Résumé	Sa pharmacie	Statut
Paiements	Complet	—	—	—	4 derniers chiffres

Le masquage est appliqué par le service avant que les données ne sortent : aucune application ne peut le contourner.

Un médecin peut différer l'affichage d'une note au patient jusqu'à l'annonce en personne d'un diagnostic difficile.

Conformité
RGPD : données de santé = catégorie particulière — minimisation, chiffrement, accès et export par le patient, analyse d'impact (AIPD) avant lancement · **HDS** : hébergement uniquement sur infrastructure certifiée (AWS Paris / Francfort) · **Conservation** : dossiers médicaux conservés 20 ans · **Paiements** : données de carte gérées uniquement par Stripe